

Module 10: Identity, Access, and Network Hardening

Intro to Networks

Brendan Shea, PhD

Rochester Community and Technical College



Outline I

- 1 Authentication
- 2 Authorization and Account Management
- 3 Network Hardening
- 4 Switch Security
- 5 Network Security Rules

Review: Security Concepts Foundations

Key Module 9 Ideas

- The CIA triad guides security tradeoffs: confidentiality, integrity, availability.
- Threats include malware, spoofing, social engineering, and denial-of-service attacks.
- Defense in depth combines layered technical and administrative controls.

Why This Matters in Module 10

This module operationalizes those ideas by implementing identity controls, hardening systems, and enforcing network security rules.

Learning Outcomes I

After completing this module, you will be able to:

- Explain **access control** and distinguish authentication from authorization.
- Compare authentication methods: passwords, MFA, tokens, certificates, and biometrics.
- Describe local authentication, centralized identity, SSO, Kerberos, and federated identity with SAML.
- Explain digital certificates, PKI trust chains, and key lifecycle management.
- Configure remote authentication concepts using RADIUS and TACACS+ design patterns.
- Apply authorization models including **RBAC** and privileged access management (PAM).
- Describe directory services with **LDAP** and secure bindings with **LDAPS**.
- Implement defense-in-depth hardening practices for devices and network services.
- Apply switch security controls including port security, 802.1X, port guards, and port mirroring.

Learning Outcomes II

- Design and troubleshoot ACL-based security rules, proxy policies, and content filtering controls.

Access Control

Think of access control as a bouncer plus a clipboard:

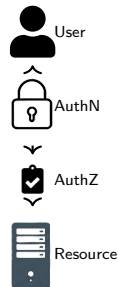
- **Authentication:** Prove who you are.
- **Authorization:** Determine what you can do.
- **Accounting:** Log what you did.

Beginner tip: Security teams often call this **AAA**. If one part is weak, the whole process is weak.

Zero-trust mindset: do not trust users or devices just because they are "inside" the network.

Typical Login Flow

1) Identify user/device → 2) Authenticate → 3) Apply authorization policy → 4) Log actions.



Authentication Methods

Authentication methods answer one question: **how do we prove identity in a way that is both usable and hard to fake?**

Most systems combine factors from these categories:

- **Something you know:** password or PIN.
- **Something you have:** phone app, smart card, or hardware token.
- **Something you are:** fingerprint, face, or voice.

Beginner takeaway

- Password-only login is easy to deploy but easy to phish.
- MFA makes account takeover much harder.
- For admins and sensitive systems, use phishing-resistant MFA whenever possible.

Quick Mental Model

Single-factor login asks for one proof. MFA asks for independent proofs from different categories.

Example: Why Phishing-Resistant MFA Matters

Phishing-resistant MFA is designed to survive a fake login page. The attacker can steal a password, but the second factor still fails unless the real site is present.

Simple comparison

- **SMS code**: better than password-only, but codes can be stolen or redirected.
- **Authenticator app**: good for many users, but not always phishing-resistant.
- **Hardware key or passkey**: best choice for admins and high-risk accounts.

Beginner rule

If the account is important enough to protect, use the strongest factor you can deploy consistently.

Local Authentication

Local authentication means each device stores its own accounts.

Where it helps

- Break-glass access during identity-server outages.
- Small isolated labs.
- Edge systems with limited features.

Why it is risky at scale

- Password policy drifts across devices.
- Departed users may remain active on forgotten systems.
- Auditing is harder because logs are fragmented.

Practical rule: keep local admin only for emergency fallback, and use centralized identity for daily operations.

Design Guardrail

Keep one documented break-glass account per critical system, and test it quarterly.

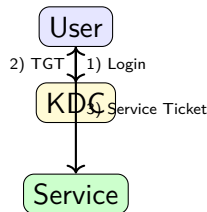
Single Sign-On and Kerberos

Beginners often confuse SSO and Kerberos. They are related, but not identical.

SSO is the user experience: sign in once, then access multiple services.

Kerberos is one protocol that can power SSO by issuing temporary tickets instead of repeatedly sending passwords.

Why this matters: less password exposure, fewer repeated prompts, and easier centralized policy enforcement.



Kerberos flow: get a Ticket Granting Ticket (TGT), then exchange it for service-specific tickets.

Digital Certificates and PKI

A certificate is like a digital ID card that binds an identity to a public key.

Systems trust that ID card because a Certificate Authority signs it.

- Common in HTTPS, VPNs, secure Wi-Fi auth, and device management.
- Validated through a chain of trust back to a root CA.

PKI building blocks

- Root and subordinate CAs.
- Registration/identity validation workflows.
- Revocation checks (CRL/OCSP).

Operational reality: most PKI outages come from expired certs or broken revocation/renewal processes.

Beginner Checkpoint

If trust breaks, check certificate validity dates, trust chain, and revocation status first.

Key Management

Key management is the difference between "we use encryption" and "encryption actually protects us."

Key Lifecycle

- 1 Generate keys with strong entropy.
- 2 Store keys in secure hardware/software vaults.
- 3 Rotate keys on schedule or incident trigger.
- 4 Revoke and destroy old keys.

Common Failure Modes

- Hardcoded secrets in scripts.
- Shared private keys across systems.
- Long-lived keys without rotation.

Best Practice

Automate key rotation and audit key access events.
If a key is copied manually, treat it as a risk event.

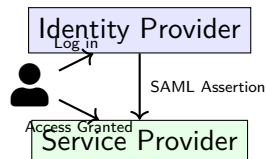
Federated Identity and SAML

Federated identity lets one organization trust another for login, which is common in cloud and partner integrations.

SAML in Plain Language

The Identity Provider sends a signed statement (assertion) that says who the user is and what attributes they have.

- Supports SSO across organizational boundaries.
- Reduces duplicate user accounts across services.
- Makes partner onboarding faster when trust is configured correctly.



Remote Authentication

RADIUS

- Common for endpoint access and 802.1X.
- Combines authentication and authorization.
- Uses UDP and shared secrets.

TACACS+

- Common for network device administration.
- Separates authentication, authorization, and accounting.
- Uses TCP and supports command-level control.

How to choose

- Use RADIUS for endpoint access workflows (wired/wireless 802.1X).
- Use TACACS+ when you need command-by-command control on network devices.

Design Guidance

- Keep local break-glass accounts with strong controls.
- Use redundant AAA servers.
- Encrypt management traffic (SSH, TLS, IPsec).

Log all admin authentication attempts for auditing and incident response.

Case Study: Cinderella's Co-Working Login Chaos

Scenario

Cinderella manages a startup from a co-working space. The team relies on CRM, source control, and invoicing SaaS tools. A contractor offboarded Friday at 5:00 PM. Monday morning, finance finds unauthorized invoice edits and a new vendor payout rule.

Initial findings:

- Contractor account was removed in CRM, but still active in invoicing.
- Login came from a residential IP at 11:42 PM Sunday.

Investigation Questions

- 1 Which identity design flaw is most likely: local accounts, missing federation, or weak deprovisioning?
- 2 What controls should be prioritized first to prevent recurrence?
- 3 Which audit data would confirm impact and recovery?

Case Study Solution: Cinderella's Co-Working Login Chaos

Recommended Response

- ❶ **Root issue:** Split identity stores and manual offboarding created a deprovisioning gap.
- ❷ **Immediate containment:** Disable all contractor sessions/tokens, lock invoice workflow changes, and revert unauthorized records.
- ❸ **Structural fix:** Move all apps to centralized identity with SSO + MFA and automated joiner/mover/leaver workflows.
- ❹ **Validation:** Correlate AAA and app audit logs to confirm timeline, source IP, impacted objects, and restoration completeness.

Security Principle

Identity controls are strongest when onboarding, authorization, and offboarding are all centralized and auditable.

Authorization and Role-Based Access Control

Authorization is where policy meets day-to-day operations.

Core ideas

- **RBAC**: Assign permissions to roles, then assign users to roles.
- **Least privilege**: Give only the access needed to do the job.
- **Separation of duties**: Split risky tasks across multiple people.

Simple role example

- Helpdesk: reset passwords.
- Network admin: configure switches.
- Security analyst: read logs, no config rights.

Why beginners should care: most access incidents are not "hacks"; they are permission mistakes.

One-Minute Workflow

Define job role, map minimum permissions, test with a non-admin account, then approve role for production use.

Privileged Access Management

PAM exists because admin credentials are high-value attacker targets.

Core controls

- Vault and rotate privileged credentials.
- Use just-in-time elevation instead of always-on admin rights.
- Require approval workflows for sensitive actions.
- Record privileged sessions for investigation and training.

Quick beginner win

- Remove shared admin logins.
- Use unique named accounts.
- Log privileged actions centrally.

What Good Looks Like

Admin rights are temporary, approved, and fully recorded.

Lightweight Directory Access Protocol (LDAP)

LDAP is the directory "phone book" for users, groups, and attributes.

- Central source for identity lookups.
- Group membership used by apps for authorization decisions.
- Standard protocol supported across many platforms.

Directory Structure

Example DN:

```
cn=alice,ou=engineering,dc=example,dc=edu
```

Operational Note

Group structure quality directly affects authorization accuracy.

LDAP Secure (LDAPS)

Plain LDAP can expose credentials and directory queries in transit. **LDAPS/StartTLS** encrypts that traffic and validates server identity with certificates.

Hardening Checklist

- Disable anonymous binds.
- Enforce TLS 1.2+ and strong cipher suites.
- Restrict bind account privileges.
- Log bind failures and unusual queries.

Example: Verifying LDAPS on Linux

Consider verifying a secure LDAP connection (Port 636) using `ldapsearch` on Linux.

Encrypted Lookup (LDAPS)

```
$ ldapsearch -H ldaps://ad.example.com:636 -D "cn=admin,dc=example,dc=com" -W
Enter LDAP Password:
# extended LDIF
#
# LDAPv3
# request bind using simple authentication
# LDAP successful bind ...
```

Case Study: Little Red's Hospital Access Mix-Up

Scenario

Little Red works at a hospital help desk. During onboarding week, she notices interns can open payroll and HR records.

After checking directory groups, she finds one broad group (`staff_all`) grants access to both help desk tools and HR compensation modules.

Additional context:

- Two temporary interns were added with full-time employee role template.
- A shared "HRAdmin" account was used during weekend support.
- No approval trail exists for payroll-export actions.

Questions

- 1 Which principle failed: least privilege, separation of duties, or both?
- 2 How should RBAC and LDAP groups be redesigned?
- 3 Which PAM controls should be added for HR-admin functions?

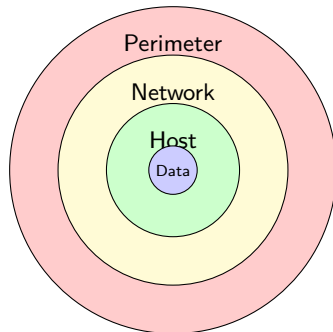
Case Study Solution: Little Red's Hospital Access Mix-Up

Recommended Response

- ❶ **Failure:** Least privilege and separation of duties were both violated by broad group mapping and shared admin usage.
- ❷ **Directory redesign:** Split `staff_all` into role-specific groups (intern, helpdesk, HR analyst, payroll admin) with minimum permissions.
- ❸ **PAM controls:** Remove shared admin account, require just-in-time elevation, and record payroll-export sessions.
- ❹ **Governance:** Add access recertification and manager approval for high-risk HR permissions.

Defense in Depth

Defense in depth means building multiple layers so one failure does not become a full compromise.



No single control is sufficient. Layer preventive, detective, and corrective controls. **Beginner pitfall:** many teams overinvest in one control (for example, firewall rules) and underinvest in identity, patching, and monitoring.

Example: Layered Hardening for a Small Office

A small office does not need exotic tools, but it does need several simple controls working together.

Layer	Example control	What it prevents
Identity	MFA for remote logins	Stolen password alone is not enough
Network	VLANs and port security	Rogue devices on wall ports
Host	Patch management and local firewall	Known exploits and exposed services
Monitoring	Syslog and alerts	Attacks that still slip through

Beginner takeaway

If any one layer fails, the others still slow the attacker down and create an audit trail.

Device and Service Hardening

Device hardening

- Change default credentials.
- Disable unused interfaces and management services.
- Restrict management plane via ACLs and trusted hosts.
- Apply patch and firmware updates on schedule.

Execution sequence: baseline config, remove defaults, lock management access, then patch.

Service hardening

- Remove unneeded daemons.
- Replace insecure protocols (Telnet, FTP, HTTP).
- Enforce secure protocols (SSH, SFTP, HTTPS, SNMPv3).
- Use host firewalls and logging.

Goal: reduce attack surface before attackers scan it.

Network Access Control and Port Security

NAC fundamentals

- Validate user/device identity before granting network access.
- Optionally check posture (compliance state) before allowing full access.

Port security basics

- Limit MAC addresses per access port.
- Bind known MAC addresses (static or sticky).
- Choose a violation action: protect, restrict, or shutdown.

Operational pattern: authenticate first, assign policy/VLAN second, monitor continuously.

Outcome

- Reduced rogue-device risk.
- Fewer unauthorized switchport activations.
- Better visibility into who connects where.

Design tip: secure edge templates make new ports safer by default.

Example: Port Security on a Lobby Switch

Port security is easiest to understand when you see the policy and the failure message together.

Simple access-port policy

```
interface gi1/0/2
  switchport mode access
  switchport port-security
  switchport port-security maximum 1
  switchport port-security mac-address sticky
  switchport port-security violation shutdown
```

What happens if a second device appears?

```
%PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occurred,
port Gi1/0/2 is shutting down.
```

The beginner rule is simple: one wall jack, one expected device, one known MAC address.

Extensible Authentication Protocol and IEEE 802.1X

802.1X controls **who can use a switch port or Wi-Fi connection** before full network access is granted.

Three roles to remember

- **Supplicant:** endpoint asking for access.
- **Authenticator:** switch or AP enforcing access.
- **Authentication server:** usually RADIUS validating credentials.

EAP Methods

- EAP-TLS (certificate-based, strong)
- PEAP (tunnel + inner auth)
- EAP-TTLS and other variants

Security Note

Certificate-based methods generally provide stronger phishing resistance.

Guard Features

- **BPDU Guard:** Shuts port on unexpected BPDUs.
- **Root Guard:** Prevents unauthorized root bridge election.
- **DHCP Snooping:** Blocks rogue DHCP offers.
- **Dynamic ARP Inspection:** Validates ARP packets.

Why It Matters

Guard features stop common L2 attacks before they spread.

Apply these controls at access ports first, then validate uplink/trunk exceptions carefully.

Example: Dealing with Port Violations

When a guard feature triggers on a Cisco switch, the port transitions to an err-disabled state.

Console Output: Port Security Violation

```
Switch#  
%PM-4-ERR_DISABLE: psecure-mac-violation error detected on Gi1/0/2,  
putting Gi1/0/2 in err-disable state  
  
Switch# show interfaces status err-disabled
```

Port	Name	Status	Reason	Err-disabled Vlans
Gi1/0/2	Lobby_Printer	err-disabled	psecure-mac-violation	

To recover, first remove the unauthorized device, then `shutdown` and `no shutdown` the port.

Port Mirroring

SPAN / Port Mirroring

Copies traffic from source ports/VLANs to a monitor port for analysis tools.

Caution

Mirroring can expose sensitive data; restrict access and protect capture storage.

Use Cases

- Security investigations and packet capture.
- IDS/IPS visibility without inline risk.
- Performance troubleshooting.

Mirror only what you need. Excess mirrored traffic can overwhelm analysis tools and hide important events.

Case Study: Jack and the Beanstalk Data Center

Scenario

Jack's cloud startup moved into a high-rise data center floor with shared contractor access. During a maintenance window, a visitor plugs a mini-switch into an open wall port to "get more jacks".

Over the next hour:

- Endpoints receive incorrect default gateway settings.
- VoIP phones flap between VLANs.
- Monitoring shows unusual BPDU and DHCP offer activity from an access port.

Questions

- 1 Which switch security controls would have prevented this incident?
- 2 Which port guard features should be enabled first?
- 3 How can port mirroring help validate root cause?

Recommended Response

- ➊ **Containment:** Shut offending access port and quarantine affected endpoints.
- ➋ **Preventive controls:** Enforce 802.1X, port security MAC limits, and disable/label unused ports.
- ➌ **L2 protection:** Enable DHCP snooping, BPDU guard, and DAI on access segments.
- ➍ **Validation:** Mirror suspect ports to confirm rogue DHCP/BPDU traffic and document incident timeline.

Security Rules and ACL Configuration

ACL fundamentals

- Rules are checked top-down; first match wins.
- There is an implicit deny at the end.
- Standard ACLs focus on source addresses.
- Extended ACLs include source, destination, protocol, and ports.

Think like a checklist: who, to where, using what protocol/port, and should it be allowed?

Beginner-safe design rules

- Keep rules explicit and documented.
- Place ACLs near the source of unwanted traffic.
- Test in stages to avoid outages.

Start with required business traffic, then add denies.

Example: Reading a Cisco ACL

An extended IP access list dictates precisely what is permitted or denied, matched top-to-bottom.

Cisco IOS Extended ACL Example

```
R1(config)# ip access-list extended GUEST_RESTRICTION
R1(config-ext-nacl)# 10 permit udp any any eq 53      ! Allow DNS
R1(config-ext-nacl)# 20 permit tcp any any eq 80       ! Allow HTTP
R1(config-ext-nacl)# 30 permit tcp any any eq 443      ! Allow HTTPS
R1(config-ext-nacl)# 40 deny ip any 10.0.0.0 0.255.255.255 ! Block Internal
R1(config-ext-nacl)# 50 permit ip any any             ! Allow Internet
```

If line 40 and 50 were swapped, no internal traffic would ever be matched by line 40 because `permit ip any any` stops the checking process.

A proxy sits between users and destinations so the network can inspect, control, and log requests.

- Enforce authentication and policy checks.
- Provide caching and centralized logging.
- Apply filtering before traffic reaches risky destinations.

Types

- Forward proxy (outbound user traffic).
- Reverse proxy (protect backend services).
- Transparent proxy (minimal client config changes).

Example: Forward vs Reverse Proxy

Concept	Forward Proxy	Reverse Proxy
Use Case	Users browsing the internet	Public accessing a company web app
Protects...	Internal clients	Internal servers
Typical Job	Filtering bad URLs, malware, caching	Load balancing, WAF, SSL offloading
Who Knows?	Client often configured to use it	Client has no idea it exists

Content Filtering

Content filtering is policy enforcement at web and DNS layers, not just "blocking websites."

Filtering Controls

- URL category blocking.
- DNS filtering for known malicious domains.
- File type controls and malware scanning.
- Safe search and acceptable-use enforcement.

Balance Security and Usability

Overly broad filters can block legitimate business workflows.

Best Practice

Tune allow/deny rules from real usage logs and exception workflows.

Start in monitor mode when possible, then enforce once false positives are understood.

Misconfigured Firewall and ACL Issues

Common Misconfigurations

- Shadowed rules that never match.
- Any-any permits left in production.
- Incorrect rule order causing unexpected blocks.
- Missing egress filtering.

Most outages come from rule order mistakes, not missing rules.

Troubleshooting Approach

- 1 Confirm intended traffic matrix.
- 2 Trace packet path and policy points.
- 3 Review logs and hit counters.
- 4 Adjust minimal rules and retest.

Roll out changes in small increments with a rollback plan and validation checklist.

Case Study: Snow White's Streaming Studio Firewall Meltdown

Scenario

Snow White runs a media startup with seven remote editors and a small on-prem render cluster. After a weekend firewall change, editors cannot sync project files or push final exports, but social media and general web browsing still work.

Firewall review shows:

- Broad 'permit any any' rule above app-specific controls.
- New deny for file-sync service placed below a general allow.
- No change ticket notes describing intended business flows.

Questions

- 1 What ACL ordering problem is most likely?
- 2 Which traffic should be explicitly permitted first?
- 3 Where should proxy/content filtering be introduced to reduce risk?

Case Study Solution: Snow White's Streaming Studio Firewall Meltdown

Recommended Response

- 1 **Policy reset:** Build a traffic matrix first (editing, sync, render, publishing), then author explicit ordered permits.
- 2 **Rule hygiene:** Remove broad any-any entries, place specific denies above broad permits, and document rule intent.
- 3 **Web control:** Route outbound browsing through authenticated proxy + category filtering for non-production traffic.
- 4 **Verification:** Test critical editor workflows and track hit counters/logs before finalizing cutover.

Validation

Use logs, counters, and user acceptance tests to confirm secure functionality.

Module 10 Summary I

- **Authentication** verifies identity using passwords, tokens, biometrics, and MFA.
- **SSO**, **Kerberos**, and **SAML** reduce credential sprawl and improve centralized trust.
- **PKI** and certificate lifecycle management are essential for secure encrypted identity exchanges.
- **Authorization** should follow least privilege with RBAC and separation of duties.
- **PAM** reduces admin-account risk via vaulting, approval, and session auditing.
- **LDAP/LDAPS** centralizes identity data while protecting directory traffic in transit.
- **Hardening** reduces attack surface by removing unused services and securing management paths.
- Switch controls (802.1X, port security, guards, mirroring) defend access layer trust boundaries.
- ACLs, proxies, and content filtering enforce business-aligned network security rules.

Identity + Hardening Complete



Any questions?